

CYBER SECURITY



Firewall

Er. Prakash Chandra Adhikari



5/3/2026

A firewall is a security system that monitors and controls incoming and outgoing network traffic based on predetermined security rules. A firewall can be hardware-based, software-based, or a combination of both.

Firewalls are used to protect a network or device from unauthorized access and can be configured to allow or block traffic based on a variety of factors, such as the source and destination of the traffic, the specific port being used, and the type of traffic. Firewalls are an important component of a secure network and can help protect against cyber threats such as malware, ransomware, and hacking attempts.

1. Network firewalls: These are hardware or software devices that control incoming and outgoing network traffic based on predetermined security rules. Network firewalls can be configured to allow or block specific types of traffic, such as HTTP or HTTPS.
2. Host-based firewalls: These are software programs that are installed on individual computers and control network traffic to and from those computers.
3. Application-level firewalls: These firewalls are designed to protect specific applications from malicious traffic. They work by inspecting the traffic that is directed at the application and only allowing traffic that meets the security rules to pass through.
4. Wireless firewalls: These firewalls are used to protect wireless networks from unauthorized access. They can be hardware devices or software programs that are installed on the network's router.
5. Cloud firewalls: These firewalls are delivered as a service and are used to protect networks and applications that are hosted in the cloud.
6. Next-generation firewalls: These firewalls combine traditional firewall features with additional features such as intrusion prevention, application control, and advanced threat protection. They are designed to provide a higher level of security than traditional firewalls.

1 FIREWALL DESIGN PRINCIPLES OR THE NEED FOR FIREWALLS

Firewalls can be an effective means of protecting a local system or network of systems from network based security threats while at the same time affording access to the outside world via wide area networks and the Internet.

Information systems in corporations, government agencies, and other organizations have undergone a steady evolution. The following are notable developments:

- Centralized data processing system, with a central mainframe supporting a number of directly connected terminals.
- Local area networks (LANs) interconnecting PCs and terminals to each other and the mainframe.
- Premises network, consisting of a number of LANs, interconnecting PCs, servers, and perhaps a mainframe or two.
- Enterprise-wide network, consisting of multiple, geographically distributed premises networks interconnected by a private wide area network (WAN).
- Internet connectivity, in which the various premises networks all hook into the Internet and may or may not also be connected by a private WAN.

1.1 FIREWALL CHARACTERISTICS

[BELL94b] lists the following design goals for a firewall:

JAN -2014[10M]

1. All traffic from inside to outside, and vice versa, must pass through the firewall. This is achieved by physically blocking all access to the local network except via the firewall.
2. Only authorized traffic, as defined by the local security policy, will be allowed to pass. Various types of firewalls are used, which implement various types of security policies.
3. The firewall itself is immune to penetration. This implies the use of a hardened system with a secured operating system. Trusted computer systems are suitable for hosting a firewall and often required in government applications.

[SMIT97] lists four general techniques that firewalls use to control access and enforce the site's security policy. Originally, firewalls focused primarily on service control, but they have since evolved to provide all four:

- **Service control:** Determines the types of Internet services that can be accessed, inbound or outbound. The firewall may filter traffic on the basis of IP address, protocol, or port number; may provide proxy software that receives and interprets each service request before passing it on; or may host the server software itself, such as a Web or mail service.
- **Direction control:** Determines the direction in which particular service requests may be initiated and allowed to flow through the firewall.
- **User control:** Controls access to a service according to which user is attempting to access it. This feature is typically applied to users inside the firewall perimeter (local users). It may also be applied to incoming traffic from external users; the latter requires some form of secure authentication technology, such as is provided in IPsec
- **Behavior control:** Controls how particular services are used. For example, the firewall may filter e-mail to eliminate spam, or it may enable external access to only a portion of the information on a local Web server.

Before proceeding to the details of firewall types and configurations, it is best to summarize what one can expect from a firewall. The following capabilities are within the scope of a firewall:

1. A firewall defines a single choke point that keeps unauthorized users out of the protected network, prohibits potentially vulnerable services from entering or leaving the network, and provides protection from various kinds of IP spoofing and routing attacks. The use of a single choke point simplifies security management because security capabilities are consolidated on a single system or set of systems.
2. A firewall provides a location for monitoring security-related events. Audits and alarms can be implemented on the firewall system.
3. A firewall is a convenient platform for several Internet functions that are not security related. These include a network address translator, which maps local addresses to Internet addresses, and a network management function that audits or logs Internet usage.
4. A firewall can serve as the platform for IPsec.

Firewalls have their limitations, including the following:

1. The firewall cannot protect against attacks that bypass the firewall. Internal Systems may have dial-out capability to connect to an ISP. An internal LAN may support a modem pool that provides dial-in capability for travelling employees and telecommuters.
2. The firewall may not protect fully against internal threats, such as a disgruntled employee or an employee who unwittingly cooperates with an external attacker.
3. An improperly secured wireless LAN may be accessed from outside the organization. An internal firewall that separates portions of an enterprise network cannot guard against wireless communications between local systems on different sides of the internal firewall.
4. A laptop, PDA, or portable storage device may be used and infected outside the corporate network, and then attached and used internally.

1.2 TYPES OF FIREWALLS

1.2.1 Packet filtering firewall

1.2.2 Stateful inspection firewall

1.2.3 Application level gateway

1.2.4 Circuit-level gateway

1.2.1 Packet filtering firewall

- A packet filtering firewall applies a set of rules to each incoming and outgoing IP packet and then forwards or discards the packet (Figure 1).
- The firewall is typically configured to filter packets going in both directions (from and to the internal network).
- Filtering rules are based on information contained in a network packet:
 - **Source IP address:** The IP address of the system that originated the IP packet (e.g., 192.178.1.1)
 - **Destination IP address:** The IP address of the system the IP packet is trying to reach (e.g., 192.168.1.2)
 - **Source and destination transport-level address:** The transport-level (e.g., TCP or UDP) port number, which defines applications such as SNMP or TELNET
 - **IP protocol field:** Defines the transport protocol.

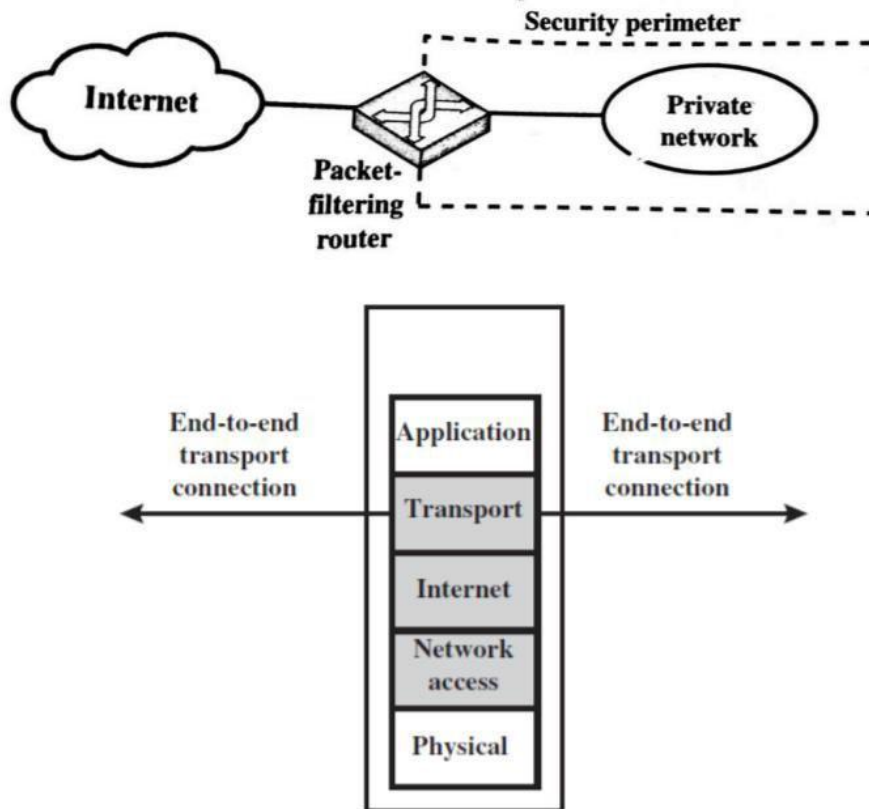


Figure 1 Packet filtering firewall

- **Interface:** For a firewall with three or more ports, which interface of the firewall the packet came from or which interface of the firewall the packet is destined for
- The packet filter is typically set up as a list of rules based on matches to fields in the IP or TCP header.
- Two default policies are possible:
 1. **Default = discard:** That which is not expressly permitted is prohibited.
 2. **Default = forward:** That which is not expressly prohibited is permitted.

Table 1, from [BELL94b], gives some examples of packet filtering rule sets. In each set, the rules are applied top to bottom. The “*” in a field is a wildcard designator that matches everything. We assume that the default = discard policy is in force.

Rule Set A

action	ourhost	port	theirhost	port	comment
block	*	*	SPIGOT	*	we don't trust these people
allow	OUR-GW	25	*	*	connection to our SMTP port

Rule Set B

action	ourhost	port	theirhost	port	comment
block	*	*	*	*	default

Rule Set C

action	ourhost	port	theirhost	port	comment
allow	*	*	*	25	connection to their SMTP port

Rule Set D

action	src	port	dest	port	flags	comment
allow	{our hosts}	*	*	25		our packets to their SMTP port
allow	*	25	*	*	ACK	their replies

Rule Set E

action	src	port	dest	port	flags	comment
allow	{our hosts}	*	*	*		our outgoing calls
allow	*	*	*	*	ACK	replies to our calls
allow	*	*	*	>1024		traffic to nonservers

Table 1 Packet-Filtering Examples

- A. Inbound mail is allowed (port 25 is for SMTP incoming), but only to a gateway host. However, packets from a particular external host, SPIGOT, are blocked because that host has a history of sending massive files in e-mail messages.
- B. This is an explicit statement of the default policy. All rule sets include this rule implicitly as the last rule.
- C. This rule set is intended to specify that any inside host can send mail to the outside. A TCP packet with a destination port of 25 is routed to the SMTP server on the destination machine. The problem with this rule is that the use of port 25 for SMTP receipt is only a default; an outside machine could be configured to have some other application linked to port 25. As this rule is written, an attacker could gain access to internal machines by sending packets with a TCP source port number of 25.
- D. This rule set achieves the intended result that was not achieved in C. The rules take advantage of a feature of TCP connections. Once a connection is set up, the ACK flag of

a TCP segment is set to acknowledge segments sent from the other side. Thus, this rule set states that it allows IP packets where the source IP address is one of a list of designated internal hosts and the destination TCP port number is 25. It also allows incoming packets with a source port number of 25 that include the ACK flag in the TCP segment. Note that we explicitly designate source and destination systems to define these rules explicitly.

- E. This rule set is one approach to handling FTP connections. With FTP, two TCP connections are used: a control connection to set up the file transfer and a data connection for the actual file transfer. The data connection uses a different port number that is dynamically assigned for the transfer. Most servers, and hence most attack targets, use low-numbered ports; most outgoing calls tend to use a higher-numbered port, typically above 1023. Thus, this rule set allows:
 - a. Packets that originate internally
 - b. Reply packets to a connection initiated by an internal machine
 - c. Packets destined for a high-numbered port on an internal machine

Packet filtering firewall Advantages:-

- Simplicity
- Transparency to users
- High speed

Disadvantages:-

- Difficulty of setting up packet filter rules
- Lack of Authentication

1.2.1.1 [WACK02] lists the following weaknesses of packet filter firewalls:

- A. Because packet filter firewalls do not examine upper-layer data, they cannot prevent attacks that employ application-specific vulnerabilities or functions. For example, a packet filter firewall cannot block specific application commands; if a packet filter firewall allows a given application, all functions available within that application will be permitted.
- B. Because of the limited information available to the firewall, the logging functionality present in packet filter firewalls is limited. Packet filter logs normally contain the same information used to make access control decisions (source address, destination address, and traffic type).
- C. Most packet filter firewalls do not support advanced user authentication schemes. Once again, this limitation is mostly due to the lack of upper-layer Functionality by the firewall.
- D. Packet filter firewalls are generally vulnerable to attacks and exploits that take advantage of problems within the TCP/IP specification and protocol stack, such as network layer address spoofing. Many packet filter firewalls cannot detect a network packet in which the OSI Layer 3 addressing information has been altered. Spoofing attacks are generally employed by intruders to bypass the security controls implemented in a firewall platform.
- E. Finally, due to the small number of variables used in access control decisions, packet filter firewalls are susceptible to security breaches caused by improper configurations. In other words, it is easy to accidentally configure a packet filter firewall to allow traffic types, sources, and destinations that should be denied based on an organization's information security policy.

1.2.1.2 Some of the attacks that can be made on packet filtering firewalls and the appropriate countermeasures are the following:

1. IP address spoofing:

- The intruder transmits packets from the outside with a source IP address field containing an address of an internal host.
- The attacker hopes that the use of a spoofed address will allow penetration of systems that employ simple source address security, in which packets from specific trusted internal hosts are accepted.
- The countermeasure is to discard packets with an inside source address if the packet arrives on an external interface. In fact, this countermeasure is often implemented at the router external to the firewall.

2. Source routing attacks:

- The source station specifies the route that a packet should take as it crosses the Internet, in the hopes that this will bypass security measures that do not analyze the source routing information.
- The countermeasure is to discard all packets that use this option.

3. Tiny fragment attacks:

- The intruder uses the IP fragmentation option to create extremely small fragments and force the TCP header information into a separate packet fragment.
- This attack is designed to circumvent filtering rules that depend on TCP header information.
- Typically, a packet filter will make a filtering decision on the first fragment of a packet. All subsequent fragments of that packet are filtered out solely on the basis that they are part of the packet whose first fragment was rejected.
- The attacker hopes that the filtering firewall examines only the first fragment and that the remaining fragments are passed through.
- A tiny fragment attack can be defeated by enforcing a rule that the first fragment of a packet must contain a predefined minimum amount of the transport header. If the first fragment is rejected, the filter can remember the packet and discard all subsequent fragments.

1.2.2 Stateful inspection firewall

- A stateful inspection packet firewall tightens up the rules for TCP traffic by creating a directory of outbound TCP connections, as shown in Table 2.
- There is an entry for each currently established connection.
- The packet filter will now allow incoming traffic to high-numbered ports only for those packets that fit the profile of one of the entries in this directory.
- A stateful packet inspection firewall reviews the same packet information as a packet filtering firewall, but also records information about TCP connections (Figure 2).

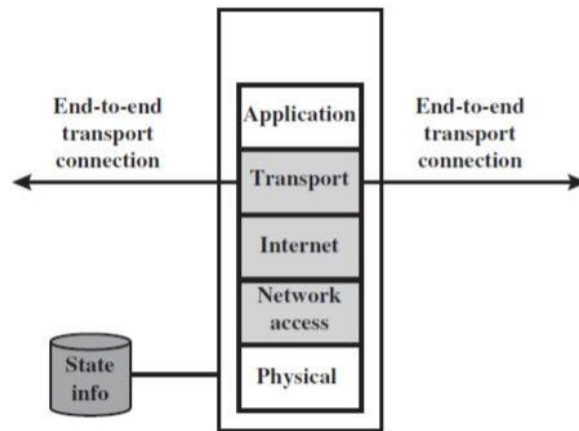


Figure 2 Stateful inspection firewall

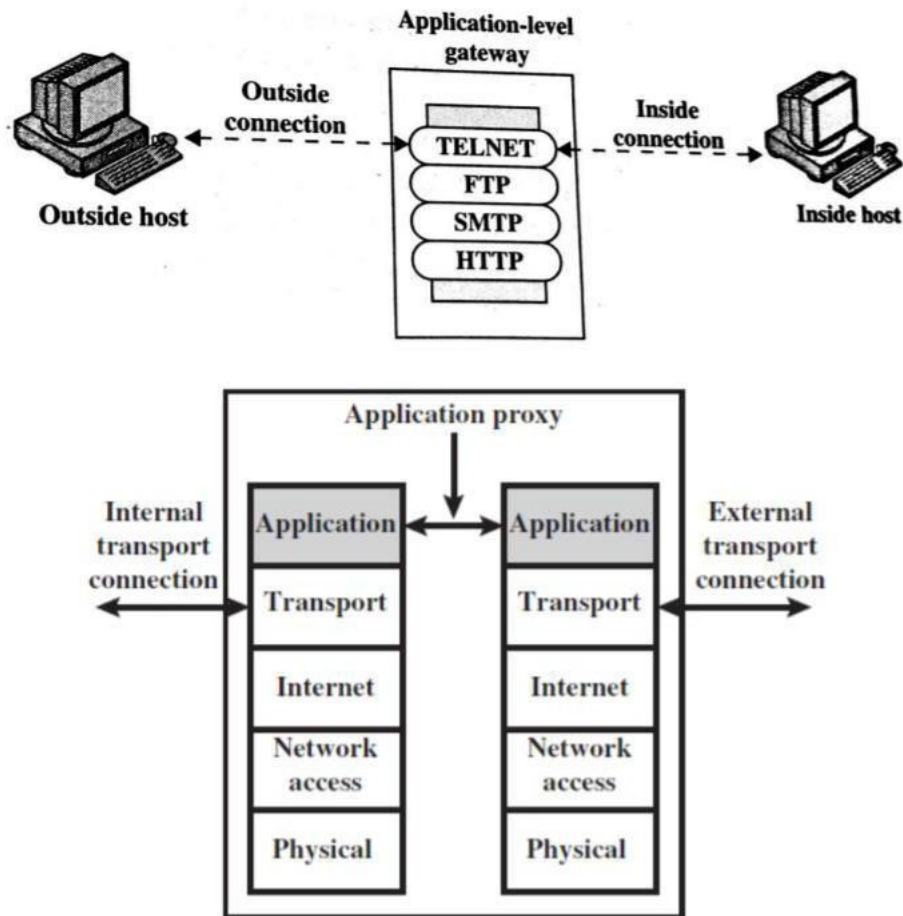
- Some stateful firewalls also keep track of TCP sequence numbers to prevent attacks that depend on the sequence number, such as session hijacking.
- Some even inspect limited amounts of application data for some well-known protocols like FTP, IM and SIPs commands, in order to identify and track related connections.

Source Address	Source Port	Destination Address	Destination Port	Connection State
192.168.1.100	1030	210.22.88.29	80	Established
192.168.1.102	1031	216.32.42.123	80	Established
192.168.1.101	1033	173.66.32.122	25	Established
192.168.1.106	1035	177.231.32.12	79	Established
223.43.21.231	1990	192.168.1.6	80	Established
2122.22.123.32	2112	192.168.1.6	80	Established
210.922.212.18	3321	192.168.1.6	80	Established
24.102.32.23	1025	192.168.1.6	80	Established
223.21.22.12	1046	192.168.1.6	80	Established

Table 2 Example Stateful Firewall Connection State Table [WACK02]

1.2.3 Application level gateway

- An application-level gateway, also called an **application proxy**, acts as a relay of application-level traffic (Figure 3).
- The user contacts the gateway using a TCP/IP application, such as Telnet or FTP, and the gateway asks the user for the name of the remote host to be accessed.
- When the user responds and provides a valid user ID and authentication information, the gateway contacts the application on the remote host and relays TCP segments containing the application data between the two endpoints.
- If the gateway does not implement the proxy code for a specific application, the service is not supported and cannot be forwarded across the firewall.
- Further, the gateway can be configured to support only specific features of an application that the network administrator considers acceptable while denying all other features.



Figur3 Application proxy firewall

Advantages:

- Higher security than packet filters
- Only need to scrutinize a few allowable applications
- Easy to log and audit all incoming traffic

Disadvantages:

- This type of gateway is the Additional processing overhead on each Connection (gateway as splice point)

1.2.4 Circuit-Level Gateway

- A fourth type of firewall is the circuit-level gateway or **circuit-level proxy** (Figure 4).

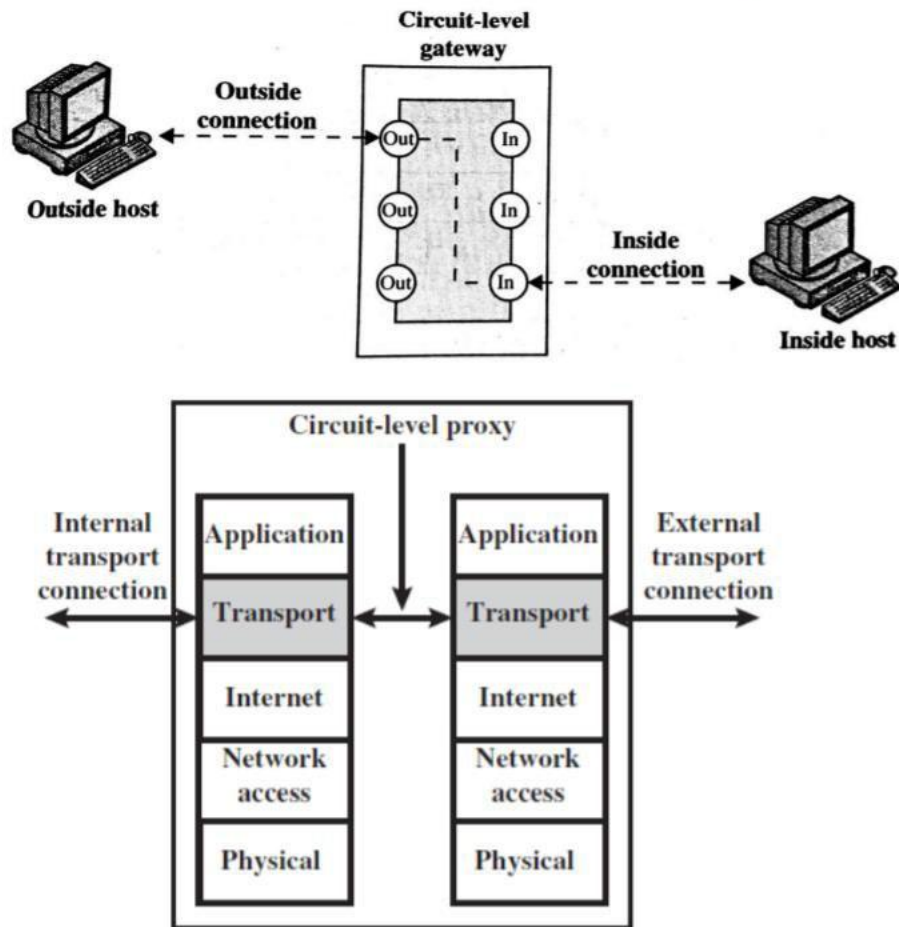


Figure 4 Circuit-level proxy firewall

- This can be a stand-alone system or it can be a specialized function performed by an application-level gateway for certain applications.
- As with an application gateway, a circuit-level gateway does not permit an end-to-end TCP connection; rather, the gateway sets up two TCP connections, one between itself and a TCP user on an inner host and one between itself and a TCP user on an outside host.

- Once the two connections are established, the gateway typically relays TCP segments from one connection to the other without examining the contents. The security function consists of determining which connections will be allowed.
- A typical use of circuit-level gateways is a situation in which the system administrator trusts the internal users.
- An example is the SOCKS package.
- A SOCK consists of the following components:
 - The SOCKS server, which often runs on a UNIX-based firewall. SOCKS is also implemented on Windows systems.
 - The SOCKS client library, which runs on internal hosts protected by the Firewall.
 - SOCKS-ified versions of several standard client programs such as FTP and TELNET. The implementation of the SOCKS protocol typically involves either the recompilation or relinking of TCP-based client applications, or the use of alternate dynamically loaded libraries, to use the appropriate encapsulation Routines in the SOCKS library.

1.4 FIREWALL CONFIGURATIONS

- In addition to the use of a simple configuration consisting of a single system, such as a single packet filtering router or a single gateway, more complex configurations are possible and indeed more common.
- Figure 5 illustrates three common firewall configurations. We examine each of these in turn.
 - a. Single-homed bastion configuration:-**
 - In the screened host firewall, single-homed bastion configuration (Figure 5(a)), the firewall consists of two systems: a packet-filtering router and a bastion host. Typically, the router is configured so that
 1. For traffic from the Internet, only IP packets destined for the bastion host are allowed in.
 2. For traffic from the internal network, only IP packets from the bastion host are allowed out.

- The bastion host performs authentication and proxy functions.
- This configuration has greater security than simply a packet-filtering router or an application-level gateway alone, for two reasons.
- First, this configuration implements both packet-level and application-level filtering, allowing for considerable flexibility in defining security policy.
- Second, an intruder must generally penetrate two separate systems before the security of the internal network is compromised.
- This configuration also affords flexibility in providing direct Internet access.
- In the single-homed configuration just described, if the packet-filtering router is completely compromised, traffic could flow directly through the router between the Internet and other hosts on the private network.

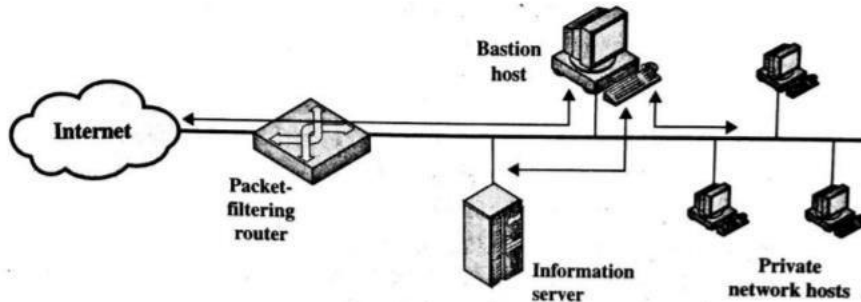
b. Screened host firewall (dual-homed bastion host):-

- The screened host firewall, dual-homed bastion configuration physically prevents such a security breach (Figure 5(b)).
- The advantages of dual layers of security that were present in the previous configuration are present here as well. Again, an information server or other hosts can be allowed direct communication with the router if this is in accord with the security policy.

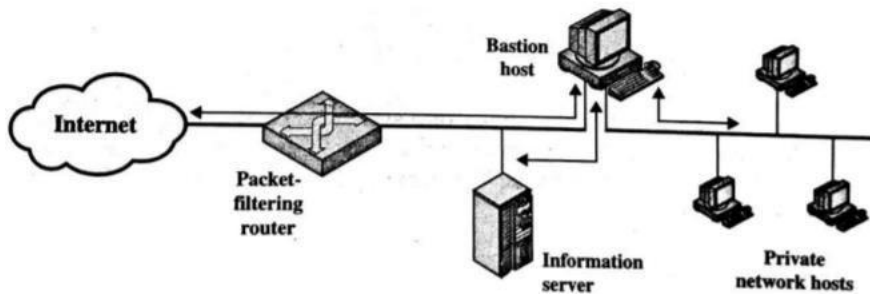
c. Screened subnet firewall:-

- The screened subnet firewall configuration of Figure 20.2c is the most secure of those we have considered.
- In this configuration, two packet-filtering routers are used, one between the bastion host and the Internet and one between the bastion host and the internal network.
- This configuration creates an isolated sub network, which may consist of simply the bastion host but may also include one or more information servers and modems for dial-in capability.
- Typically, both the Internet and the internal network have access to hosts on the screened subnet, but traffic across the screened subnet is blocked.
- This configuration offers several advantages:-
 - There are now three levels of defense to thwart intruders.
 - The outside router advertises only the existence of the screened subnet to the Internet; therefore, the internal network is invisible to the Internet.

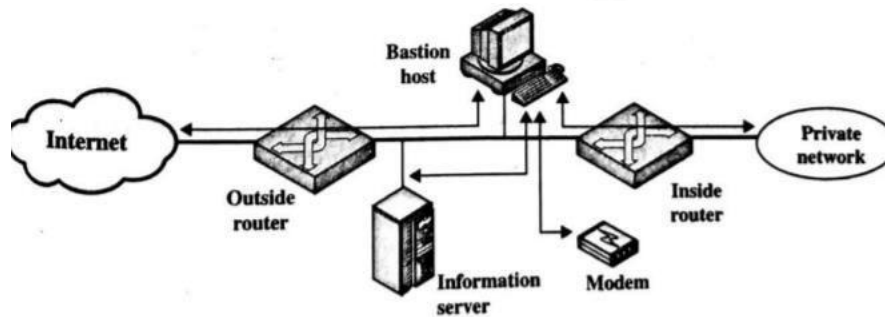
- Similarly, the inside router advertises only the existence of the screened subnet to the internal network; therefore, the systems on the inside network cannot construct direct routes to the Internet.



(a) Screened host firewall system (single-homed bastion host)



(b) Screened host firewall system (dual-homed bastion host)



(c) Screened-subnet firewall system

Fig.

Figure 5 Firewall Configurations